

Project: Governance, Risk & Compliance - Protect the Attacker

A cybersteps project

Date: 30. January 2026

Participants: Gregor

Executive Summary

The goal of this project is to perform a security audit on a Kali Linux virtual machine using **Lynis**, review findings against the CIS Debian Linux Benchmark, and implement hardening controls to improve system security.

Since no critical warnings were found, I focused on the Lynis suggestions and chose 7 potential risks to mitigate, based on the potential impact on the Kali Linux virtual machine.

1. Initial Findings

First I did the lynis scan:

```
sudo lynis audit system
```

The results showed no critical warnings but 47 suggestions:

```
-[ Lynis 3.1.6 Results ]-
```

```
Great, no warnings
```

```
Suggestions (47):
```

```
★ Install libpam-tmpdir to set $TMP and $TMPDIR for PAM sessions [DEB-0280]  
- Related resources  
★ Website: https://cisofy.com/lynis/controls/DEB-0280/
```

And a hardening index of 61:

Lynis security scan details:

Scan mode:

Normal ☒ Forensics ☐ Integration ☐ Pentest ☐

Lynis modules:

- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]

Details:

Hardening index : 61 [#####]

Tests performed : 268

Plugins enabled : 1

Software components:

- Firewall [X]
- Intrusion software [X]
- Malware scanner [X]

Files:

- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat

Lynis suggestions

DEB-0280 – libpam-tmpdir

Lynis suggestion: Install libpam-tmpdir to set \$TMP and \$TMPDIR for PAM sessions

CIS mapping: CIS Debian 13 – Section 5.4.x (PAM Configuration)

Implication: Kali frequently installs cutting-edge packages. Could slow down workflow or block installs. Usefull for production Kali systems, but not so much for disposable VMs.

DEB-0811 – apt-listchanges

Lynis suggestion: Install apt-listchanges to display significant changes prior to any upgrade

CIS mapping: CIS Debian 13 – 1.4.x (Change Management / Updates)

Implication: Relevant because Kali updates often. No negative impact for PT-tooling.

BOOT-5122 – GRUB boot loader password

Lynis suggestion: Set a password on GRUB boot loader to prevent altering boot configuration

CIS mapping: CIS Debian 13 – 1.5.2

Implication: Relevant especially for laptops or shared lab environments. In this case for a disposable VM it is not relevant.

BOOT-5180 – Determine runlevel and startup services

Lynis suggestion: Determine runlevel and services at startup

CIS mapping: - CIS Debian 13 – 2.2.x (Service Configuration)

Implication: Relevant because Kali enables multiple services by default. Unnecessary services could increase attack surface.

AUTH-9230 – Password hashing rounds

Lynis suggestion: Configure password hashing rounds in /etc/login.defs

CIS mapping: CIS Debian 13 – 5.4.4

Implication: No impact on pentesting tools. Strong baseline control

AUTH-9262 – PAM password strength module

Lynis suggestion: Install a PAM module for password strength testing

CIS mapping: CIS Debian 13 – 5.4.2

Implication: Not really necessary in single-user VM-lab-environments.

STRG-1846 – Disable FireWire storage drivers

Lynis suggestion: Disable FireWire storage drivers

CIS mapping: CIS Debian 13 – 1.1.24

Implication: FireWire is rarely used and therefor no drivers needed. Safe to disable.

PKGS-7370 – debsums package integrity

Lynis suggestion: Install debsums for verification of packages

CIS mapping: CIS Debian 13 – 1.3.2

Implication: Good for detecting compromise. No downsides.

PKGS-7394 – apt-show-versions

Lynis suggestion: Install apt-show-versions for patch management

CIS mapping: CIS Debian 13 – 1.4.x (Patch Management)

Implication: Identifies outdated packages. Useful in rolling distributions.

NETW-3200 – Disable unused protocols

Lynis suggestion: Determine if protocol 'dccp, sctp, rds, tipc' is really needed on this system

CIS mapping: CIS Debian 13 – 3.1.x (Network Configuration)

Implication: Lowers attack surface. These protocols are rarely used.

FIRE-4590 – Firewall configuration

Lynis suggestion: Configure a firewall to filter incoming and outgoing traffic

CIS mapping: CIS Debian 13 – 3.5.x (Configure host-based firewall)

Implication: Context-dependent. Can interfere with pentesting, but still a good idea, if exposed to networks.

FILE-7524 – Restrict file permissions

Lynis suggestion: Consider restricting file permissions

CIS mapping: - CIS Debian 13 – 5.5.x

Implication: Prevents unauthorized access.

Mitigation Plan Table:

Finding	Description	CIS Control	Mitigation Plan	Status
DEB-0811	no apt-listchanges	1.4.x	install apt-listchanges	Not Started
AUTH-9230	no password hashing rounds	5.4.4	configure password hashing rounds	Not Started
STRG-1846	FireWire storage drivers	1.1.24	Disable FireWire storage drivers	Not Started
PKGS-7370	debsums package integrity	1.3.2	install debsums	Not Started
PKGS-7394	apt-show-versions	1.4.x	install apt-show-versions	Not Started
NETW-3200	unused protocols	3.1.x	Disable unused protocols	Not Started
FIRE-4590	Firewall configuration	3.5.x	Configure a firewall to filter network	Not Started

2. Mitigation Process & Evidence

DEB-0811 – apt-listchanges

apt-listchanges displays important package changes (security fixes, removals, behavior changes) **before** upgrades are applied via APT.

This aligns with CIS recommendations for administrator awareness during system updates.

```
sudo apt install apt-listchanges
```

Then I have to configure it to my liking with:

```
sudo dpkg-reconfigure apt-listchanges
```

AUTH-9230 – Password hashing rounds

Password hashing rounds determine how many iterations are used when hashing passwords (e.g. SHA-512).

Increasing the number of rounds makes offline brute-force attacks significantly slower.

To configure it I need to open the /etc/login.defs-file:

```
sudo nano /etc/login.defs
```

and add these lines:

```
ENCRYPT_METHOD SHA512  
SHA_CRYPT_MIN_ROUNDS 5000  
SHA_CRYPT_MAX_ROUNDS 10000
```

Lynis suggestion AUTH-9230 identified that password hashing rounds were not explicitly configured.

The system was configured to enforce SHA-512 password hashing with defined minimum and maximum rounds via /etc/login.defs.

This aligns with CIS Debian Linux Benchmark section 5.4.4 and increases resistance against offline password cracking attacks.

The change applies to newly set passwords, consistent with Debian authentication behavior.

STRG-1846 – Disable FireWire storage drivers

FireWire (IEEE 1394) supports **direct memory access (DMA)**, which can allow attackers with physical access to read or modify system memory and bypass OS-level protections.

Create a blacklist file:

```
sudo nano /etc/modprobe.d/blacklist-firewire.conf
```

and add these lines:

```
blacklist firewire-core  
blacklist firewire-ohci  
blacklist firewire-sbp2
```

PKGS-7370 – debsums package integrity

debsums verifies the integrity of installed Debian packages by comparing installed files against known-good checksums from the package database.

It helps detect **tampering, corruption, or unauthorized modification** of system files.

```
sudo apt install debsums
```

To run a checkup:

```
sudo debsums -s
```

(Only shows checksum mismatches)

Lynis suggestion PKGS-7370 recommended installing debsums to verify package integrity.

The tool was installed and used to compare installed files against known-good checksums.

This aligns with CIS Debian Linux Benchmark section 1.3.2 and provides an integrity-monitoring capability to detect unauthorized modifications.

PKGS-7394 – apt-show-versions

apt-show-versions displays the version and update status of installed Debian packages and helps identify packages that are **outdated or no longer receiving updates**.

```
sudo apt install apt-show-versions
```

Lynis suggestion PKGS-7394 recommended installing apt-show-versions to improve patch management visibility.

The tool was installed and used to identify the update status of installed packages.

This aligns with CIS Debian Linux Benchmark section 1.4.x and supports ongoing system maintenance and vulnerability management.

NETW-3200 – Disable unused protocols

Unused network protocols increase the kernel attack surface.

Disabling protocols that are not required reduces exposure to kernel-level vulnerabilities.

Similar to the FireWire-disable, we need to create a blacklist-file:

```
sudo nano /etc/modprobe.d/blacklist-net-protocols.conf
```

and add this:

```
install dccp /bin/true  
install sctp /bin/true  
install rds /bin/true  
install tipc /bin/true
```

Lynis suggestion NETW-3200 recommended reviewing and disabling unused network protocols.

The protocols DCCP, SCTP, RDS, and TIPC were disabled persistently via /etc/modprobe.d.

This aligns with CIS Debian Linux Benchmark section 3.1.x and reduces the system's kernel-level attack surface.

The control was assessed as applicable to Kali Linux, as these protocols are not required.

FIRE-4590 – Firewall configuration

A host-based firewall filters incoming and outgoing traffic, reducing exposure to unauthorized access and network attacks.

To configure a firewall on Kali you can use nftables or ufw.

I decided to use ufw and therefor installed it:

```
sudo apt install ufw
```

Set default rules:

```
sudo ufw default deny incoming
sudo ufw default allow outgoing
```

Now you could allow specific services like ssh for example.

```
sudo ufw allow ssh
```

Enable the firewall:

```
sudo ufw enable
```

Lynis suggestion FIRE-4590 recommended configuring a firewall to filter incoming and outgoing traffic.

UFW was installed and configured with a default policy of denying incoming and allowing outgoing connections.

This aligns with CIS Debian Linux Benchmark section 3.5.x and reduces the system's network attack surface.

The firewall is active and persistent across reboots.

For Kali Linux, exceptions can be added for pentesting activities while maintaining baseline security.

3. Final Results & Conclusion

I was able to solve 7 potential security risks:

Finding	Description	CIS Control	Mitigation Plan	Status
DEB-0811	no apt-listchanges	1.4.x	install apt-listchanges	Solved
AUTH-9230	no password hashing rounds	5.4.4	configure password hashing rounds	Solved
STRG-1846	FireWire storage drivers	1.1.24	Disable FireWire storage drivers	Solved

Finding	Description	CIS Control	Mitigation Plan	Status
PKGS-7370	debsums package integrity	1.3.2	install debsums	Solved
PKGS-7394	apt-show-versions	1.4.x	install apt-show-versions	Solved
NETW-3200	unused protocols	3.1.x	Disable unused protocols	Solved
FIRE-4590	Firewall configuration	3.5.x	Configure a firewall to filter network	Solved

After restarting I ran lynis again:

```
sudo lynis audit system
```

The hardening index changed from 61 to 66.

```
Lynis security scan details:

Scan mode:
Normal [X] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status      [?]
- Security audit         [V]
- Vulnerability scan     [V]

Details:
Hardening index : 66 [##### ]
Tests performed : 269
Plugins enabled : 1

Software components:
- Firewall               [V]
- Intrusion software     [X]
- Malware scanner        [X]

Files:
- Test and debug information  /var/log/lynis.log
- Report data                : /var/log/lynis-report.dat
```

The Kali Linux system was successfully hardened by implementing seven high-value CIS-aligned controls.

The Lynis audit confirmed improvements in the hardening index, and all implemented changes were persistent and verified.

This project demonstrates **systematic assessment, mapping to CIS benchmarks, and practical implementation of security controls**, providing a strong baseline for secure system

operations.